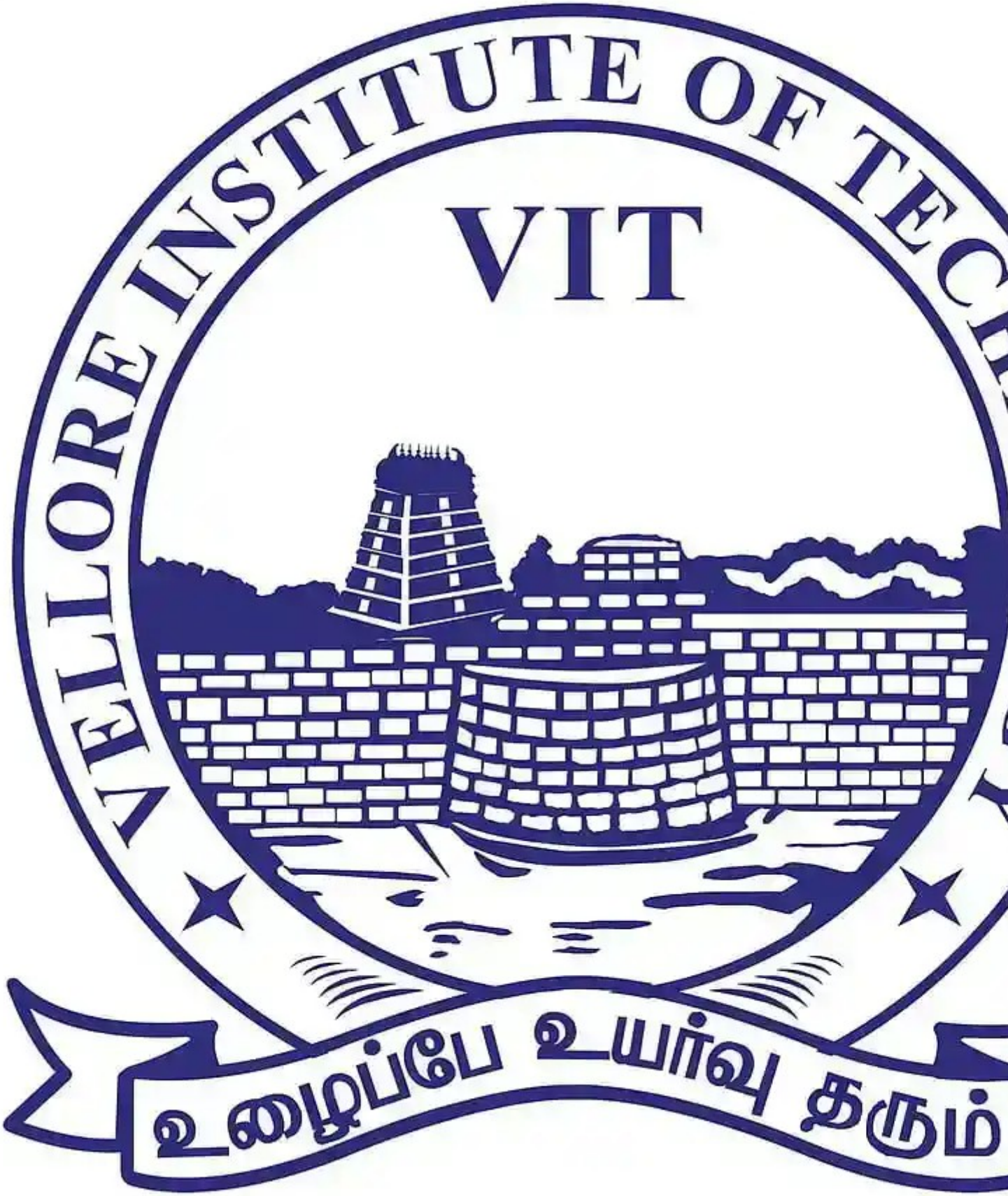

VELLORE INSTITUTE OF TECH
VIT
உழைப்பே உயர்வு தரும்

OPTIMUS Review 3 — Final Project Completion Report

Project: Cold-Storage Security Monitor — Multi-Layer Data Integrity Monitoring and Purple-Team Evaluation Platform
Team: Team 12, Vellore Institute of Technology (VIT), SCOPE / CSBS, Information Security
Members: K. Pavan Kumar Reddy (24BBS0173), Durga Prassad (24BBS0195), Sri Charan (24BBS0173)
Repository: https://github.com/durga-61/optimus-purple-team
Base implementation commit: `8b57f16` (this report and the Review 3 artifacts are added in the working tree)
Report date: 26 October 2026
Live demo: `http://127.0.0.1:8000` after `python run.py` (verified on 26 October 2026)
PDF version: `docs/REVIEW3_FINAL_REPORT.pdf`

> **Scope of this report.** This is the final Review 3 report. It covers the working system and live demo, the final repository and reproduction instructions, the final measured results and comparison, an authoritative real-world cold-chain incident case study, the mapping to the Review 1 threat model, a scaled-down attack executed against the working system, limitations, future work, and individual contributions.

Contents

1. Final Working System and Live Demo
2. Final Results and Comparison
3. Real-World Incident Case Study
4. Limitations
5. Future Work
6. Individual Contribution Statement
7. Review 3 Requirements Checklist
8. References
9. Appendix

Executive Summary

OPTIMUS is a working, reproducible cold-storage data-integrity monitoring and attack-simulation platform. The final system has three portals (Defender, Sensor Transmitter, Attack Simulator), a dual data-source architecture (the real University of Hohenheim 9-sensor cold-storage dataset and a synthetic ERP-linked warehouse simulator), a five-layer detection pipeline, a SHA-256 audit chain, and an operator-gated self-hardening loop.

The final held-out benchmark contains 12,000 observations (2,400 normal, 9,600 attacks across six

classes). At a strict 0.00% false-positive rate, the static multi-layer Defender achieves **76.93% recall / 86.96% F1 / 81.54% accuracy**. Dynamic invariant mining raises this to **94.40% recall / 97.12% F1 / 95.52% accuracy**, still at 0.00% FPR. On the same held-out test set, a One-Class SVM reaches 33.33% recall / 50.00% F1 and PCA reaches 74.99% recall / 85.71% F1. The full test suite passes: **317 passed, 2 warnings**.

The Review 3 incident case study is the **October 2026 campaign against internet-exposed refrigeration controllers in French supermarkets**, documented by the French national CERT (CERT-FR) in advisory **CERTFR-2026-ALE-012**. Attackers reached Danfoss AK-SM/AK-SC, Copeland xweb, and Dixell xweb controllers, raised refrigeration temperatures (reported up to 50 °C), spoiled food across hundreds of stores, and in some cases started fires. The vulnerabilities included a hidden "code-of-the-day" authentication bypass (CVE-2025-41450), post-authentication command injection (CVE-2025-41451), and Nginx configuration injection (CVE-2025-41452), with affected stores reportedly running outdated firmware.

A scaled-down attack was executed against the live OPTIMUS pipeline using the same experiment engine and ground-truth isolation as the production simulator. The results are deliberately mixed:

- A sustained **+25 °C** controller runaway was detected: `SUSPICIOUS` at the first sample (risk 0.384) and `POTENTIAL_ATTACK` at the second (risk 0.433).
- A **+1.5 °C** change held for six samples remained `NORMAL` (risk 0.022–0.029) because it stayed inside the semantic envelope.
- A replayed valid frame that hid an actual **46.2 °C** reading was `NORMAL` (risk 0.061).
- A forced sensor dropout was `NORMAL` (risk 0.052), because the platform treats loss of telemetry as a data-quality event.

The case study therefore shows the exact boundary of the project: OPTIMUS can detect the **effect** of a large, honest temperature excursion, but it cannot prevent the compromise, detect the controller-level cause, or detect an attacker who stays in-envelope, replays normal telemetry, or suppresses the sensor. Those are the main gaps and the basis of the future-work plan.

A critical, honest finding is also reported: on **unmodified real-data playback**, the current Hohenheim envelope/spatial calibration produced **504 alert states in 600 sequential observations (84.0%)**, with the first alert at step 93. This is a calibration defect (ambient sensor vs cold-room sensors, a hard-coded 4–16 °C envelope, a max-minus-min spatial rule, and an ML baseline fitted on the first 120 rows), not an attack. The controlled benchmark remains the validated evaluation; the real-data path needs per-zone calibration before production use.

---

1. Final Working System and Live Demo

1.1 What is delivered

Deliverable	Status	Location
Working system with a live demo	Complete	FastAPI app, three portals, `/api/docs`

Deliverable	Status	Location
Final source repository	Complete	https://github.com/durga-61/optimus-purple-team
README with setup, usage, reproduction	Complete	`README.md`
Final results and comparison	Complete	§2, `evaluation_results/`
Real-world incident case study	Complete	§3, `docs/REVIEW3_CASE_STUDY_RESULTS.md`
Scaled-down simulated attack	Complete	`scripts/review3_case_study.py`
Individual contribution statement	Complete	§6

The final application is a FastAPI service with three product portals and one legacy redirect:

1. **Defender Portal (`/`)** — live classification, composite risk, five explainable detection layers, received 9-sensor telemetry, alerts, event history, and raw evidence.
2. **Sensor Transmitter Portal (`/transmitter`)** — Hohenheim dataset provenance, playback cursor, 9 DHT22 channels, dropout badges, rolling temperature window, and delivery receipts for `POST /api/warehouse/transmit`.
3. **Attack Simulator Portal (`/simulator`)** — six dataset-compatible attack scenarios, target-sensor selection, mutation-diff preview, baseline/attack execution, TP/TN/FP/FN metrics, filterable history, RFC 4180 CSV export, and a self-contained reproducibility script.
4. **Legacy route (`/operations`)** — `HTTP 307` redirect to `/transmitter`.

The earlier AI attacker console remains in `attacker_app/`, but it is not on the final quantitative evaluation path. The final benchmark and case study use deterministic attack transformations so that every number in this report is reproducible.

1.2 Architecture

```
Real Hohenheim dataset (9 DHT22 sensors, 156,835 records)
        │
        ├── Sensor Transmitter Portal ── POST /api/warehouse/transmit
        │
        ▼
DefenderService
  1. Ingestion + data-quality analysis
  2. IsolationForest anomaly detection (ledger mode / environmental mode)
  3. Semantic invariants C1–C4 + approved mined invariants
  4. Temporal persistence and EWMA decay
  5. Structural graph correlation (NetworkX)
  6. Joint decision fusion (bounded weights, tiered rules)
  7. SHA-256 audit chain
  8. Operator-gated self-hardening loop
```

```
        │
        ├── Defender Portal (live evidence)
        ├── Attack Simulator Portal (ExperimentEngine)
        └── REST API / OpenAPI
```

The synthetic ERP-linked simulator remains the only source with inventory, capacity, and shipment ledgers. It is used for C1/C2 evaluation and the controlled benchmark. The Hohenheim source supplies real physical telemetry but has no ERP ledgers, so C1 and C2 correctly return `NOT_APPLICABLE` with zero penalty rather than fabricated data.

1.3 Design choices

Design choice	Rationale	Trade-off
Defense in depth (five layers)	No single detector covers all six attack classes; the ablation shows ML-only recall of 5.17% and semantic-only recall of 61.01%.	More components, more calibration surfaces, and more ways to produce correlated false positives.
Deterministic semantic invariants first	C1/C2 are hard physical/accounting equalities; a violation is high-confidence evidence.	Rules need domain knowledge and do not cover in-envelope manipulation.
Unsupervised ML as a supporting layer	IsolationForest needs no labelled attacks and can flag multivariate outliers.	Static model; concept drift and narrow baselines cause false positives.
Temporal persistence	A single blip is weak evidence; sustained violation is stronger and reduces transient false alarms.	Slow attacks that never cross a layer threshold still evade.
Structural graph correlation	Maps anomalies to coupled ledgers/zones and distinguishes isolated from multi-source events.	The graph is hand-built; it is not learned from the facility.
Passive monitoring, not inline control	Deployable alongside existing SCADA/ERP without touching the process; cannot cause operational risk.	Cannot prevent an attack or drive an actuator to a safe state.
Real dataset + synthetic ledger source	Ecological validity for physical telemetry; controllable C1/C2 attacks and reproducibility from the simulator.	The real source has no ledgers; the synthetic source is not real data.
Ground-truth isolation	The Defender never receives `is_attack`, `expected_label`, or `attack_type`; the	Requires careful plumbing and explicit tests.

Design choice	Rationale	Trade-off
	experiment record keeps truth separately.	
Operator approval for hardening	No automatic parameter change can be activated without a human; proposals are validated and reversible.	Slower response; a compromised operator can still approve a bad change.
In-memory SHA-256 audit chain	Simple, fast, and tamper-evident within a process; no external dependency for the demo.	Does not survive restart; an attacker with memory-write access can recompute the chain.
Three portals	Separation of concerns: defender evidence, data provenance, and controlled attack evaluation.	More surface area and duplicated frontend logic.

1.4 Security mechanisms

Mechanism	Implementation	Threat addressed	Evidence
C1 capacity consistency	`inventory + free_capacity ≈ total_capacity` (0.5 t tolerance)	Capacity/ledger manipulation	100% recall on `capacity_manipulation`
C2 inventory-flow consistency	`I_t ≈ I_{t-1} + inbound − outbound` (0.5 t tolerance)	Inventory tampering	100% recall on `inventory_manipulation`
C3 operating envelope	Temperature/humidity bounds; Hohenheim 4–16 °C, 50–95% RH; simulator 1–7 °C, 60–85% RH; door-event suppression	Sensor spoofing / environmental tampering	C3 warning on the +25 °C case
C4 spatial consistency	`max(T) − min(T) ≤ 5 °C` across active sensors	Localized sensor spoofing	`SUSPICIOUS` on +8 °C at SENSOR04
IsolationForest	50 trees, contamination 0.03, anomaly threshold 0.60; separate ledger and environmental models	Multivariate outliers / coordinated weak manipulation	Supporting evidence in fusion; ML-only recall 5.17%
Temporal engine	10-observation window, 0.85 decay, consecutive-violation persistence	Recurring/sustained manipulation	Escalation from `SUSPICIOUS` to `POTENTIAL_ATTACK` after 2 steps
Structural graph	NetworkX topology of ledgers, zones, sensor clusters	Cross-subsystem / multi-source	`CORRELATED` on environmental cases; `MULTI_SOURCE` on

Mechanism	Implementation	Threat addressed	Evidence
		compromise	ledger+environment cases
Joint decision fusion	Weights semantic 0.40, temporal 0.25, structural 0.20, ML 0.15; tiered rules; risk thresholds 0.20/0.40	Combined evidence and explanation	Final classification and risk score
SHA-256 audit chain	Genesis-linked event hash chain over every analysis/security event	Retroactive evidence tampering	33-event chain valid; tampered copy returns `HASH_MISMATCH`
Operator-gated hardening	Miss → proposal → validation → approval → activation → rollback	Unsafe automatic tuning	Audit lifecycle: unauthorized activation blocked, rollback restored 0.5 t
Ground-truth isolation	Attack metadata stripped before `DefenderService.analyze()`	Label leakage / inflated results	Tested in `test_experiment_engine.py`
API protection	Loopback-only local demo mode; operator token for state-changing endpoints; CORS allow-list; no-cache headers	Unauthorized control of the demo	Live API verified; token path enforced off-loopback

1.5 Live demo walkthrough

Start the system (from the repository root):

```
python scripts/fetch_dataset.py      # one-time, MD5-verified download (~5.8 MB)
python run.py                        # starts http://127.0.0.1:8000
```

For a machine without the dataset:

```
python run.py --source simulator
```

Demo sequence (about four minutes):

1. Open `http://127.0.0.1:8000/`. The Defender Portal shows the current observation, the 9-sensor array (with `DROPOUT` badges for missing channels), the five layers, and the joint verdict.
2. Open `http://127.0.0.1:8000/transmitter`. Seek to step **30**, show provenance (Zenodo 15130001, CC-BY-4.0), and click **Transmit to Defender**. The delivery receipt and the Defender's `NORMAL` verdict appear.
3. Open `http://127.0.0.1:8000/simulator`. Choose `temperature_manipulation`, target `SENSOR01`, magnitude `25`, step `30`. Click **Run Attack Experiment**. Expected: `SUSPICIOUS`, risk ≈ 0.384,

evidence from C3, C4, ML, temporal, and structural layers. Run steps 31 and 32 (or use the API sequence in §3.6) to reach `POTENTIAL_ATTACK` (risk ≈ 0.433–0.473).

4. In the same portal, run `temperature_manipulation` with magnitude `1.5` at steps 30–35. Expected: all `NORMAL`; this is the in-envelope miss.
5. Run `replay_substitution` with `replay_step = 0` at step 30. Expected: `NORMAL`; this is the replay/authenticity gap.
6. Open `http://127.0.0.1:8000/api/security/audit-chain/verify`. Expected: `valid: true`, with the event count and latest hash.
7. Export the evaluation history with `GET /api/experiments/history/export` (RFC 4180 CSV) and show the reproducibility record for any experiment.

Verified live-demo checks on 26 October 2026:

Check	Result
`GET /api/health`	`{"status":"healthy","data_source":"hohenheim","defender":"ready"}`
`GET /`	HTTP 200
`GET /transmitter`	HTTP 200
`GET /simulator`	HTTP 200
`POST /api/experiments/baseline` step 30	`NORMAL`, `TRUE_NEGATIVE`, risk 0.035
`POST /api/experiments/attack` +25 °C step 30	`SUSPICIOUS`, `TRUE_POSITIVE`, risk 0.384

> **Demo caveat.** Use step 30 (or another stable segment) for the real-data demo. Unmodified sequential playback from step 0 produces repeated false alerts after step 93 because of the calibration issue documented in §2.10 and §4.1. The synthetic simulator mode does not have this issue.

1.6 Setup, usage, and reproduction

Prerequisites: Python 3.10+ (tested on 3.12.12), Git, and ~100 MB free disk (dataset + SQLite cache).

```
git clone https://github.com/durga-61/optimus-purple-team.git
cd optimus-purple-team
python -m venv .venv
source .venv/bin/activate           # Windows: .\.venv\Scripts\Activate.ps1
pip install -r requirements.txt
python scripts/fetch_dataset.py
pytest tests/ -q                    # 317 passed, 2 warnings
python run.py
```

Reproduce the final results:

```
# 1. Canonical full benchmark (12,000 test observations; charts included)
python -m app.evaluation.cli --split test \
  --output-dir evaluation_results/final_benchmark

# 2. Advanced experiments: adaptive fusion, invariant mining, baselines,
#    evasion frontier, audit lifecycle, dataset manifests and checksums
python -c "from app.evaluation.advanced_experiments import run_all_experiments; \
run_all_experiments(seed=42, num_normal=12000, num_attack_per_class=2000, \
output_dir='evaluation_results')"

# 3. Review 3 case study (scaled-down refrigeration-controller attacks)
python scripts/review3_case_study.py

# 4. Verify exported checksums
python - <<'PY'
import json, hashlib, pathlib
root = pathlib.Path("evaluation_results")
manifest = json.load(open(root / "artifacts_checksums.json"))
bad = []
for rel, expected in manifest.items():
    got = hashlib.sha256((root / rel).read_bytes()).hexdigest()
    if got != expected:
        bad.append(rel)
print("checksum mismatches:", bad)
PY
```

All experiments use seed 42, deterministic timestamps, and the same 60/20/20 chronological splits. The split hashes are recorded in `evaluation_results/dataset_manifest.json`; the artifact checksums are in `evaluation_results/artifacts_checksums.json`.

---

2. Final Results and Comparison

2.1 Evaluation protocol

Item	Value
Dataset generation	12,000 normal + 12,000 attack observations (2,000 per class)
Attack classes	capacity manipulation, inventory manipulation, sensor spoofing, replay, coordinated weak, multi-source
Split	60% train (7,200 normal only), 20% validation (2,400 normal + 2,400 attack), 20% test (2,400 normal + 9,600 attack)
Leakage control	Training contains no attacks; thresholds/weights/invariants use validation only; test is

Item	Value
	scored once; labels never enter `DefenderService`
Random seed	42
Host	Intel Core i5-1035G1, 8 threads, 6.8 GiB RAM, Ubuntu 26.04.1, kernel 7.0.0-38, CPU-only
Runtime	Python 3.12.12, scikit-learn 1.9.1, NumPy 2.5.4, pandas 3.0.6, FastAPI 0.154.0, Pydantic 2.14.1, NetworkX 3.7, Matplotlib 3.11.2, pytest 9.1.1

The evaluation criterion is the production decision: a sample is detected if the joint classification is `POTENTIAL_ATTACK` or `COORDINATED_ATTACK`, or if a security alert is generated. The ablation table also reports the `joint_with_suspicious` triage criterion, which includes `SUSPICIOUS`; this is more sensitive but has a small FPR.

2.2 Automated test suite

```
317 passed, 2 warnings in 13.18s
```

The two warnings are a Starlette/httpx deprecation warning and a pytest class-scoped-fixture deprecation warning; neither affects behavior. The suite covers the defender pipeline, all six attack classes, audit chaining and tamper detection, hardening and rollback, the Hohenheim adapter, the experiment engine, the API, and the frontend asset contract. Dataset-dependent tests skip automatically on a fresh clone until `scripts/fetch_dataset.py` has run.

2.3 Overall held-out test performance

System	Accuracy	Precision	Recall	F1	FPR	Evasion
OPTIMUS static (rule decision)	0.8154	1.0000	0.7693	0.8696	0.0000	0.2307
OPTIMUS + mined invariants	**0.9552**	**1.0000**	**0.9440**	**0.9712**	**0.0000**	**0.0560**
OPTIMUS + mined invariants + adaptive fusion	0.9552	1.0000	0.9440	0.9712	0.0000	0.0560
One-Class SVM	0.4667	1.0000	0.3333	0.5000	0.0000	0.6667
PCA reconstruction	0.7999	1.0000	0.7499	0.8571	0.0000	0.2501

Confusion counts (static / invariant-augmented):

System	TP	FP	TN	FN
Static	7,385	0	2,400	2,215
Invariants	9,062	0	2,400	538

Static episode detection is **99.17% (476/480 episodes)** at a mean latency of **0.06 steps**; replay is the only class with a non-zero mean latency (0.34 steps, P95 5 steps). The invariant-augmented system closes most of the coordinated-weak gap while keeping FPR at zero on this benchmark.

2.4 Per-attack-class recall

Attack class	Static	Invariants	Comment
Capacity manipulation	1.0000	1.0000	C1 is decisive.
Inventory manipulation	1.0000	1.0000	C2 is decisive.
Sensor spoofing	1.0000	1.0000	C3/C4 plus ML.
Replay attack	0.5681	0.6637	Stationary, in-envelope replay is not observable from passive telemetry.
Coordinated weak	0.0475	1.0000	Learned residual/occupancy invariants close the gap.
Multi-source	1.0000	1.0000	Structural correlation plus semantic evidence.

The replay class is the honest weak point. At full attack strength, every detector tested — including the invariant-augmented system — still had **100% replay evasion** in the evasion-frontier experiment. Detecting a valid historical frame replayed under a new timestamp requires cryptographic freshness (nonces, monotonic counters, edge signatures), not statistical anomaly detection.

2.5 Ablation study

Configuration	Detection rate	FPR	Precision	Recall	F1	Accuracy
ML only	0.0517	0.0029	0.9861	0.0517	0.0982	0.2407
Semantic only	0.6101	0.0000	1.0000	0.6101	0.7578	0.6881
Temporal only	0.8326	0.0037	0.9989	0.8326	0.9082	0.8653
Structural only	0.6611	0.0029	0.9989	0.6611	0.7957	0.7283

Configuration	Detection rate	FPR	Precision	Recall	F1	Accuracy
Semantic + temporal	0.8407	0.0037	0.9989	0.8407	0.9130	0.8718
Semantic + structural	0.7694	0.0029	0.9991	0.7694	0.8693	0.8149
Joint decision	0.7693	0.0000	1.0000	0.7693	0.8696	0.8154
Joint + suspicious triage	0.8373	0.0029	0.9991	0.8373	0.9111	0.8692

No single layer is sufficient. ML-only recall is 5.17%; semantic-only is 61.01%. The joint decision is the only configuration that combines 76.93% recall with zero FPR on this test set. The suspicious triage adds 6.8 percentage points of recall at a 0.29% FPR.

2.6 Adaptive fusion

Adaptive weights were learned only from trusted validation labels under a hard validation FPR ceiling of 0.001.

Weight	Static	Adapted	Safety bounds
Semantic	0.40000000	0.49092757	0.20–0.60
Temporal	0.25000000	0.11031382	0.10–0.40
Structural	0.20000000	0.34875861	0.10–0.40
ML	0.15000000	0.05000000	0.05–0.35

Criterion	Static	Adaptive
Validation F1	0.858094	0.867390
Validation recall	0.752083	0.765833
Validation precision	0.998893	1.000000
Validation FPR	0.000833	0.000000
Test rule recall	0.7693	0.7693
Test rule F1	0.8696	0.8696
Test risk-threshold recall	0.7538	0.7691
Test risk-threshold F1	0.8596	0.8695

Honest interpretation. Adaptive fusion improved the validation criterion and was adopted, but it did not change held-out rule classification because the deterministic rule paths are driven by semantic evidence, not by the weighted risk score. The small risk-threshold difference (0.7691 vs 0.7538) is not a material improvement. The static weights are safer to explain in a viva; the adaptive path is retained as an experimental feature with a validation gate.

2.7 Dynamic invariant mining

The miner discovered **9** candidates, validated/activated **8**, and rejected **1**.

Candidate	Kind	Tolerance	Validation coverage	Attack detection	FPR	Status
INV-CAPACITY-RESIDUAL	residual / capacity	0.100	1.000000	0.666250	0.000000	ACTIVE
INV-FLOW-RESIDUAL	residual / flow	0.100	1.000000	0.434583	0.000000	ACTIVE
INV-OCCUPANCY-IDENTITY	residual / occupancy	0.250	1.000000	0.416667	0.000000	ACTIVE
INV-TEMP-ENVELOPE	envelope / temperature	0.000	1.000000	0.275000	0.000000	ACTIVE
INV-HUMIDITY-ENVELOPE	envelope / humidity	0.000	0.999583	0.108333	0.000417	ACTIVE
INV-TEMP-SLEW	slew / temperature	0.247	1.000000	0.183750	0.000000	ACTIVE
INV-HUMIDITY-SLEW	slew / humidity	0.949	1.000000	0.184167	0.000000	ACTIVE
INV-INVENTORY-SLEW	slew / inventory	3.211	1.000000	0.204167	0.000000	ACTIVE
INV-SHIPMENT-RATE	rate / shipment	2.625	1.000000	0.000000	0.000000	REJECTED — no discrimination

Effect on the held-out test set: recall **76.93% → 94.40%** (+17.47 pp), F1 **86.96% → 97.12%** (+10.16 pp), accuracy **81.54% → 95.52%** (+13.98 pp), FPR unchanged at **0.00%**. The shipment-rate candidate was rejected because its attack detection rate (0.0000) was below the 0.02 minimum; this rejection is evidence that the miner is not simply accepting every candidate.

2.8 Evasion frontier

Attack magnitude was swept from 0.10 to 1.00 across all six classes. Lower evasion is better.

Configuration	Mean evasion	Evasion at full strength
OPTIMUS static	0.4332	0.3542
OPTIMUS adaptive	0.4332	0.3542
OPTIMUS + mined invariants	**0.1667**	**0.1667**
OPTIMUS combined	**0.1667**	**0.1667**
One-Class SVM	0.7778	0.6667
PCA	0.2235	0.1667

Evasion at full strength, by class (lower is better):

Attack class	OPTIMUS static	OPTIMUS combined	One-Class SVM	PCA
Capacity manipulation	0.0%	0.0%	100.0%	0.0%
Inventory manipulation	0.0%	0.0%	100.0%	0.0%
Sensor spoofing	12.5%	0.0%	0.0%	0.0%
Replay attack	100.0%	100.0%	100.0%	100.0%
Coordinated weak	100.0%	0.0%	100.0%	0.0%
Multi-source	0.0%	0.0%	0.0%	0.0%
All classes	**35.4%**	**16.7%**	**66.7%**	**16.7%**

Mined invariants roughly halve mean evasion (43.32% → 16.67%) and eliminate coordinated-weak evasion at all tested strengths. Replay remains 100% evasive at full strength for every detector. PCA is close at full strength (16.7% evasion, matching the combined system) because the synthetic coordinated-weak and sensor attacks are strongly linear; on the mean it is worse (22.35% vs 16.67%), and it does not match the combined system on overall recall (74.99% vs 94.40%) or on C1/C2 evidence.

2.9 Audit chain and lifecycle verification

Check	Result
Audit chain valid	Yes
Audit events	13 in the lifecycle run; 33 in the case-study sequence
Unauthorized activation blocked	Yes
Rejected proposal logged	Yes
Full lifecycle present	Yes
Rollback restored baseline parameters	Yes (`c1_tolerance` restored to 0.5)
Tampered event detected	Yes — `HASH_MISMATCH`

The chain is an in-memory SHA-256 hash chain. It provides runtime tamper evidence and detects insertion, deletion, reordering, and content changes in the current process. It does not survive a restart and is not a substitute for append-only external storage.

2.10 Performance and real-data playback

Processing overhead (1,000 synthetic normal observations, fitted IsolationForest, same host):

Metric	Value
Mean	5.988 ms
Median	6.029 ms
P95	8.270 ms
P99	9.613 ms

The earlier Review 2 measurement on the hardened configuration was 8.189 ms mean (8.242 ms hardened, +0.053 ms / +0.65%). The current measurement is in the same order of magnitude; the difference reflects the benchmark path and model fit, not a regression. The ML layer dominates runtime; the semantic, temporal, structural, and decision layers are small.

Real-data playback validation (limitation):

Metric	Value
Sequential unmodified observations	600

Metric	Value
Alert states (`SUSPICIOUS` / `POTENTIAL_ATTACK` / `COORDINATED_ATTACK`)	504
Alert rate	84.0%
First alert	Step 93, `SUSPICIOUS`, risk 0.251, 21.1 °C
After step 120	Effectively 100% alert rate in the sample

This is **not** an attack result. It is a calibration defect in the real-data path: the primary `temperature` field is SENSOR01 (cold-room entry/ambient), while other sensors are in colder zones; the Hohenheim C3 envelope is hard-coded to 4–16 °C; C4 uses a global max-minus-min across zones; the ML environmental model is fitted on the first 120 rows; and the pre-`Begin` transient (steps < 120) gets a wider 25 °C allowance. The benchmark results in §2.3 are from the synthetic ledger dataset, where the detectors are calibrated to the simulated cold room. The real-data path needs per-zone calibration before it can be treated as a production monitor.

2.11 Comparison with Review 2 and with baselines

Item	Review 2	Review 3 (final)	Status
Automated tests	274 passed	**317 passed**	Expanded and passing
Static recall / F1	0.7693 / 0.8696	0.7693 / 0.8696	Reproduced
Invariant recall / F1	0.9440 / 0.9712	0.9440 / 0.9712	Reproduced
One-Class SVM recall	0.3333	0.3333	Reproduced
PCA recall	0.7499	0.7499	Reproduced
Evasion (combined, full strength)	0.1667	0.1667	Reproduced
Data sources	Synthetic	Real Hohenheim + synthetic	Major addition
Portals	Two-part system	Three portals + live demo	Major addition
Real-data FPR	Not measured	**84.0% on 600 steps**	New critical finding

Item	Review 2	Review 3 (final)	Status
Case study	None	French refrigeration campaign (CERT-FR)	New
Reproducibility script	Partial	`scripts/review3_case_study.py` + checksums	New

The measured metrics are stable across Review 2 and Review 3. The major final-year additions are the real dataset, the three-portal product, the live experiment engine, the case study, and the honest real-data calibration finding.

Comparison with external methods. One-Class SVM and PCA are standard unsupervised baselines, not tuned production detectors. Both are fitted on normal training data only, calibrated on validation data under FPR ≤ 0.001, and scored on the same held-out test split. OPTIMUS beats One-Class SVM by 61.07 percentage points of recall and PCA by 19.41 points. PCA is close at full strength on the synthetic evasion frontier (16.7% evasion, matching the combined system) because the synthetic attacks are strongly linear, but it is worse on mean evasion (22.35% vs 16.67%) and it collapses on replay (0% recall) and capacity manipulation (50% recall). This is exactly why the multi-layer design uses semantic invariants in addition to statistical detectors.

---

3. Real-World Incident Case Study

3.1 Selection and authoritative source

Incident: October 2026 cyberattacks on internet-exposed refrigeration controllers at French supermarkets.
Primary authoritative source: CERT-FR (French national CERT, ANSSI), advisory **CERTFR-2026-ALE-012**, "Incident de sécurité ciblant les contrôleurs à distance des installations de réfrigération," first version 12 October 2026, last updated 16 October 2026 — https://cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-012/.
Technical source: Claroty Team82, "Freeze the Controller, Defrost the Food: Uncovering Vulnerabilities in Danfoss Refrigeration Controllers" — https://claroty.com/team82/research/freeze-the-controller-defrost-the-food-uncovering-vulnerabilities-in-danfoss-refrigeration-controllers.
Vendor source: Danfoss security advisory DSA-2025-08-01 — https://www.danfoss.com/en/service-and-support/coordinated-vulnerability-disclosure/danfoss-security-advisories/dsa-2025-08-01/.
Impact reporting: Reuters, 12 October 2026 — https://www.reuters.com/business/retail-consumer/french-supermarket-chain-intermarche-hit-by-cyberattack-150-stories-targeted-2026-10-12/; The Register, 13 October 2026 — https://www.theregister.com/2026/10/13/20267/.

Why this incident. It is a direct cold-chain case: the targets are refrigeration controllers in supermarkets and cold-storage units, the attack changes the physical preservation environment, and the impact is spoiled food and fires. It is also recent enough to test whether the project's threat model covers the 2026 attack surface rather than only the 2013–2021 cases that most teams use. The French

campaign is distinct from the commonly selected Target (2013), Oldsmar (2021), and Stuxnet (2010) cases.

Source discipline. CERT-FR is authoritative for the affected equipment and the recommended response. Claroty is authoritative for the vulnerabilities it discovered and disclosed. Reuters and The Register are used only for reported store counts, temperatures, and physical impact. The exact initial access vector and whether the Claroty CVEs were the exploited path have **not** been confirmed by the authorities; Danfoss stated that affected stores were running outdated firmware. The root-cause analysis below separates confirmed facts from the team's assessment.

3.2 Incident summary, timeline, and impact

What happened. A wave of compromises hit remote refrigeration controllers used by French supermarkets. The affected equipment included Danfoss AK-SM and AK-SC series, Copeland xweb, and Dixell xweb controllers. Attackers reached management interfaces that were exposed to the public internet or reachable through weak remote-access arrangements. They changed refrigeration operation so that temperatures rose; public reporting describes temperatures up to 50 °C, food spoilage, fresh-produce shortages, and fires in some stores. CERT-FR warned that attack campaigns were probably still ongoing and recommended removing internet exposure, restricting access to a VPN or protected network, updating firmware, enabling Danfoss "Strict" security mode, and changing default passwords.

Timeline (public reporting):

Date	Event
2025–2026 (disclosure)	Claroty Team82 privately reports the Danfoss AK-SM 800A vulnerabilities (CVE-2025-41450/41451/41452); Danfoss releases firmware R4.3.1 (DSA-2025-08-01).
12 Oct 2026	CERT-FR publishes the initial alert (CERTFR-2026-ALE-012); Reuters reports Intermarché was hit, with about 150 stores targeted.
13 Oct 2026	CERT-FR expands the affected list to Copeland xweb and Dixell xweb; The Register reports temperatures up to 50 °C, food discarded, and fires in some stores; Carrefour (80), Coopérative U (80), and Monoprix (~5% of 490) are reported affected.
16 Oct 2026	CERT-FR updates its recommendations; the alert remains active and warns that campaigns are likely ongoing.
26 Oct 2026	This report is prepared; no public post-incident root-cause report from the victims is available.

Impact (publicly reported):

Dimension	Reported impact
Stores affected	Intermarché ~150; Carrefour ~80; Coopérative U ~80; Monoprix ~5% of 490 (≈25). Publicly reported total ≈335 stores across four banners.
Physical	Refrigeration temperatures reportedly raised as high as 50 °C; perishable food spoiled; fresh-produce shortages; fires in some cases.
Safety	The cited sources do not report casualties; the food-safety risk is the central concern.
Economic	Not quantified in the cited public sources; loss includes food, cleanup, equipment, and downtime.
Sector	Food retail and cold chain; the attack targeted equipment essential to preserving fresh products.
Detection	The incidents were discovered through physical/operational symptoms and store-level response, not through central cyber monitoring.

3.3 Root cause: vulnerabilities, technical failures, and process failures

A. Vulnerabilities (confirmed by research/advisory):

ID	CVSS	Type	Effect
CVE-2025-41450	8.2	Improper authentication	Hidden "code-of-the-day" authentication path; a code derived from the device date could bypass the configured administrator password and create an authenticated admin session.
CVE-2025-41451	7.6	Command injection	Post-authentication command injection in the alarm-to-mail configuration; could lead to remote code execution.
CVE-2025-41452	5.4	External control of configuration	Authenticated Nginx configuration injection; could manipulate traffic and cause a denial of service.

Claroty found **2,765 exposed AK-SM 800A management interfaces** in Censys; The Register reported more than **4,500 exposed endpoints**, more than half in France. The management interface is the operational control center for refrigeration circuits, temperature thresholds, schedules, alarms, users, and maintenance. Internet exposure of that interface is contrary to good practice and is the enabling condition for the campaign. Danfoss fixed the vulnerabilities in firmware **R4.3.1**; the affected stores were reportedly running outdated firmware.

B. Technical failures:

- **Internet-exposed management plane.** The controller web interface was directly reachable, not confined to a management VLAN, VPN, or jump host.
- **Weak authentication.** A hidden date-derived code-of-the-day path bypassed normal password

verification; default or shared credentials and the absence of MFA compound the risk.
- **Unpatched firmware.** Affected equipment was running firmware older than R4.3.1; the vendor's "Strict" security mode and default-password rotation were not consistently applied.
- **Flat/remote-access architecture.** Remote troubleshooting convenience took priority over segmentation; controllers were reachable from the public internet or from broadly accessible vendor networks.
- **No command-level audit or anomaly detection.** There was no central monitoring of setpoint changes, schedule changes, login events, or firmware versions; the attack was detected through physical effects.
- **No independent fail-safe.** The controller was both the control point and the monitoring point; compromising it removed the ability to see the true temperature.

C. Process failures:

- **Exposure management.** Thousands of controllers were internet-facing; there was no inventory or continuous exposure scan tying controller firmware to public exposure.
- **Patch governance.** The vendor had a fix, but the installed base did not apply it; ownership of patching across retailer, refrigeration contractor, and OEM was unclear.
- **Vendor and remote-access governance.** Remote maintenance access was not gated by strong authentication, least privilege, time-bound sessions, or network segmentation.
- **Monitoring and detection.** No central OT monitoring or alerting on controller commands; store staff and physical symptoms were the detection mechanism.
- **Incident response.** Response was store-by-store (disconnect, reset, reconfigure); CERT-FR had to issue the cross-industry warning. A pre-agreed playbook and fail-safe procedure would have shortened the window.
- **Food-safety integration.** Cyber incident response and cold-chain food-safety response were not treated as one process.
- **Assurance.** There is no public evidence of pre-deployment penetration testing, exposure review, or tabletop exercises for this attack path.

D. What is confirmed vs assessed:

Claim	Status
Many Danfoss AK-SM/AK-SC, Copeland xweb, and Dixell xweb controllers were compromised	Confirmed by CERT-FR
Internet exposure of management interfaces is contrary to good practice and enabled the campaign	Confirmed by CERT-FR
Danfoss AK-SM 800A had a code-of-the-day auth bypass, command injection, and Nginx config injection in older firmware	Confirmed by Claroty/Danfoss
Affected stores ran outdated firmware	Reported by Danfoss to press
Temperatures reached 50 °C and food spoiled; some fires	Reported by The Register/retailers; not

Claim	Status
	independently verified in this report
The Oct 2026 attackers exploited CVE-2025-41450/51/52	**Not confirmed** by authorities; plausible but unproven
The initial access vector was direct internet exposure of the controller	**Assessed**; consistent with the evidence, not confirmed

3.4 Mapping to the Review 1 threat model

Review 1 protected the **integrity of operational and IoT data** against an attacker who can compromise one or more data sources. Its attack types were capacity manipulation, inventory manipulation, sensor spoofing, replay, coordinated manipulation, and multi-source manipulation. Its trust assumption was that the Defender runtime is initially authentic and may retain some independent information; its known boundary was that if every independent source is compromised consistently, the system cannot determine which state is true.

Review 1 element	Incident realization	Coverage / gap
Protected asset: IoT/operational data integrity	The attacker changed refrigeration setpoints and the physical temperature; the *control* data and the *telemetry* were both at risk.	The model covers telemetry integrity but not **actuator/command integrity**.
IoT sensor spoofing	The controller is the source of temperature data; if it reports false values, the Defender sees a false state.	C3/C4/ML can detect a large excursion only if the reported values reflect it.
Administrative record tampering	Not the incident (no ERP ledgers in scope); the supermarket incident is physical/OT.	C1/C2 are not exercised; the real dataset has no ledgers.
Coordinated stealth manipulation	Multiple controllers/stores manipulated in one campaign; per-store changes can be small.	Per-store detection is possible; **cross-store correlation is absent**.
Replay	Not reported in the incident; an attacker controlling the controller can replay normal telemetry while the plant is hot.	The case study demonstrates this exact **miss**.
Multi-source manipulation	Controller + sensor + physical process; the attacker did not need to touch the ERP.	Structural graph covers ledgers+environment, not controller+network.
Trust boundary: Defender	The controller (the data source) was the	The assumption is violated; the

Review 1 element	Incident realization	Coverage / gap
runtime authentic	compromised component.	Defender can be fed fabricated data.
Known boundary: all independent sources compromised	A compromised controller can hide the true temperature; the independent source is gone.	This is a real-world instance of the stated boundary.
AI attacker boundary	Not relevant; the actor was external, not the sandboxed AI attacker.	No change.

Threat-model update implied by the case study. Add **controller/actuator command integrity**, **device identity and firmware provenance**, **network exposure**, and **cross-site campaign correlation** to the Review 1 model. The protected asset should be extended from "data integrity" to "data and command integrity for the cold chain," with a new impact class: food spoilage, safety, and physical damage.

3.5 Would OPTIMUS have prevented, detected, or missed each stage?

The platform is a passive monitor. It has no inline enforcement, no controller authentication, no network telemetry, and no actuator control. "Prevented" is therefore "no" for every stage. The meaningful question is detection.

Stage	What happened in the incident	OPTIMUS behavior	Verdict
1. Exposure and scanning	Internet-facing controllers discovered by scanning	No asset inventory, exposure scan, or network telemetry	**Missed**
2. Initial access / auth bypass	Hidden code-of-the-day or weak credentials → admin session	No controller authentication logs; no endpoint/network telemetry	**Missed**
3. Command injection / RCE	Post-auth command injection could execute code	No controller process/OS telemetry	**Missed**
4. Setpoint change / temperature rise	Refrigeration driven to unsafe temperature	If the controller reports the real temperature, C3/C4/ML/temporal detect a large sustained excursion: `SUSPICIOUS` after 1 sample, `POTENTIAL_ATTACK` after 2	**Detected (effect only, after the fact)**
5. Telemetry spoof / replay /	Controller reports normal values while the plant is	Replay, hidden-hot replay, and forced dropout all produce `NORMAL` in the case	**Missed**

Stage	What happened in the incident	OPTIMUS behavior	Verdict
suppression	hot, or telemetry is lost	study	
6. Multi-store campaign	Hundreds of stores affected	Per-store monitoring can alert per store; no fleet-level correlation	**Partially detected / cross-site missed**
7. Food spoilage / fire	Physical impact	No actuator control, interlock, or safety response; audit evidence only	**Missed (prevention)**

Narrative. If the attacker changes the setpoint and the controller honestly reports the resulting temperature, OPTIMUS will catch the excursion quickly — one sample for `SUSPICIOUS`, two for `POTENTIAL_ATTACK` — and produce an explainable alert plus audit evidence. That is a real, useful capability. But the incident's attacker controlled the controller. The attacker can therefore report a normal frame, replay a historical frame, or suppress the sensor; in all three cases the Defender sees a consistent normal state. The case study's hidden-hot replay is the clean demonstration: the actual plant is at 46.2 °C, the controller reports 21.2 °C, and the Defender returns `NORMAL` with risk 0.061. The system would not have prevented the French campaign; it might have shortened the detection window only if the controllers reported the truth.

3.6 Scaled-down simulated attack on the working system

Environment and method.

- Data: University of Hohenheim 9-sensor cold-storage telemetry, step 30 (2024-09-02, 5-second sampling). Baseline: 21.2 °C, 61.5% RH, 6 active sensors, no door event.
- Pipeline: the live `DefenderService` and the same `ExperimentEngine` used by the Attack Simulator portal.
- Ground truth: retained in the experiment record only; the observation passed to the Defender has `is_attack_injected=False` and `attack_type=None`.
- Each case resets the app state, seeds step 29, and runs the attack at step 30 (or a 30–35 sequence).
- Reproduction: `python scripts/review3_case_study.py`; raw results: `evaluation_results/review3_case_study.json`; readable table: `docs/REVIEW3_CASE_STUDY_RESULTS.md`.

Results.

Case	What it emulates	Steps	Defender verdict	Outcome	Risk	Verdict
`baseline_normal`	Clean observation	30	`NORMAL`	`TRUE_NEGATIVE`	0.035	Correctly clear
`sustained_setpoint_runaway`	Controller driven to	30–32	`SUSPICIOUS` →	`TRUE_POSITIVE`	0.384 →	**Detected**

Case	What it emulates	Steps	Defender verdict	Outcome	Risk	Verdict
	~46 °C		POTENTIAL_ATTACK		0.473	
subtle_in_envelope_change	+1.5 °C for six samples, still inside 4–16 °C	30–35	NORMAL	FALSE_NEGATIVE	0.022–0.029	**Missed**
localized_cross_sensor_spoof	+8 °C on SENSOR04 only	30	SUSPICIOUS	TRUE_POSITIVE	0.325	**Detected**
valid_frame_replay	Replay step 0 under step 30	30	NORMAL	FALSE_NEGATIVE	0.061	**Missed**
telemetry_suppression	Suppress SENSOR01	30	NORMAL	FALSE_NEGATIVE	0.052	**Missed**
hidden_hot_telemetry_replay	Actual 46.2 °C, reported 21.2 °C	30	NORMAL	FALSE_NEGATIVE	0.061	**Missed**

Escalation detail for the detected case:

Step	Prediction	Risk	Semantic	Temporal	Structural	Contributing layers
30	SUSPICIOUS	0.384	C3 + C4 warning	persistence 1	CORRELATED	ML 0.557, C3, C4, temporal 0.32, structural 0.50
31	POTENTIAL_ATTACK	0.433	C3 + C4 warning	persistence 2	CORRELATED	ML 0.551, C3, C4, temporal 0.52, structural 0.50
32	POTENTIAL_ATTACK	0.473	C3 + C4 warning	persistence 3	CORRELATED	ML 0.551, C3, C4, temporal 0.68, structural 0.50

Audit evidence. After the three-step sequence, the SHA-256 chain was valid with **33 events** and tip `ceb3e593d5cc7737…`. A tampered copy produced `HASH_MISMATCH` at event index 3. This shows that the evidence path works, even though the system cannot stop the attack.

Real-data playback check. The same script played 600 unmodified observations sequentially: 504 alert states (84.0%), first alert at step 93 (`SUSPICIOUS`, risk 0.251). This is the calibration limitation described in §2.10 and §4.1, not a successful attack. It is included because it is the most important engineering finding of Review 3.

Interpretation.

1. **The system detects the effect, not the cause.** A large, honest temperature excursion is caught in one to two samples (5–10 seconds of dataset time) with explainable evidence. That is useful for a cold-chain operator.
2. **The system misses the stealth path.** A +1.5 °C change inside the 4–16 °C envelope is invisible to every layer; over hours, that is enough to compromise a cold chain. The French attackers did not need to stay subtle; they drove temperatures to 50 °C. But a future attacker who understands the monitor can stay in-envelope.
3. **The system misses the authenticity path.** A valid historical frame, a replayed normal frame that hides a hot plant, or a forced dropout all read as normal. The Review 1 boundary — "if every independent source is compromised consistently, the system cannot determine which state is true" — is exactly what happened at the controller level.
4. **The system is a monitor, not a control.** It cannot close a valve, change a setpoint, or fail safe. The incident's impact was physical; prevention requires controller/network security and safety interlocks, not only analytics.
5. **The real-data calibration gap is the top engineering issue.** The 84% alert rate on unmodified playback means the current Hohenheim path is not production-ready. The controlled benchmark is valid for the synthetic ledgers, but the real-data path needs per-zone envelopes and representative ML baselines.

3.7 Gaps and recommendations

Priority	Gap	Recommendation	Owner
P0	Internet-exposed controller management interfaces	Remove public exposure; require VPN/jump host/management VLAN; continuous exposure scanning	Facility/OT
P0	Weak/hidden authentication and default credentials	MFA where supported; unique credentials; disable vendor backdoors; least privilege; session logging	Facility/OT + vendor
P0	Outdated firmware	Inventory every controller and firmware version; patch to R4.3.1+; contractual patch SLA	Facility + vendor
P0	No command-level audit	Ingest controller login, setpoint, schedule, and firmware events into the SIEM/Defender; alert on changes outside maintenance windows	Project + facility
P1	Passive telemetry can be spoofed/replayed	Signed telemetry, device identity/attestation, monotonic counters/nonces, edge HMAC; treat unauthenticated telemetry as untrusted	Project + vendor
P1	Real-data calibration (84% FPR)	Zone-aware C4, per-sensor envelopes, representative ML baseline, concept-drift	Project

Priority	Gap	Recommendation	Owner
		monitoring, re-calibration on normal data	
P1	No cross-site correlation	Fleet-level analytics: same controller model/firmware, same time window, same setpoint pattern across stores	Project/industry
P1	In-memory audit	Append-only external storage/SIEM; retention and legal hold; hash anchoring	Project
P2	No safety interlock	Independent over-temperature cutout, mechanical/thermal fail-safe, local alarm; do not rely on the controller	Facility
P2	No response playbook	Tabletop exercises, store-level isolation procedure, factory-reset/reconfigure runbook, communication plan	Facility
P2	Vendor/remote-access governance	Time-bound sessions, MFA, least privilege, logging, contractual security requirements, right-to-audit	Procurement + OT
P3	Food-safety/cyber integration	Joint incident classification; cold-chain product disposition; regulatory reporting	Operations + food safety

Project-specific next steps.

1. Add a `ControllerEvent` data source and a command-integrity layer: login, setpoint change, schedule change, firmware version, configuration change. Alert on out-of-window changes and on changes that are not correlated with a work order.
2. Add a replay guard: monotonic sequence number, nonce, timestamp window, HMAC/signature from the edge. The current `step <= last_step` check is not enough because a replayed frame can carry a new step.
3. Make C4 zone-aware and calibrate C3 per sensor/zone. The current global max-minus-min rule mixes a 21 °C ambient sensor with 6 °C cold-room sensors; that is the main cause of the 84% real-data alert rate.
4. Re-fit the environmental IsolationForest on a representative normal window (not the first 120 rows) and monitor drift.
5. Persist the audit chain and ship alerts to a SIEM/webhook; add a response playbook and a "maintenance window" allow-list.
6. Add cross-store/fleet correlation: the same controller model/firmware and the same setpoint pattern across stores is a strong campaign signal.
7. Add an independent safety channel (e.g., a simple thermostat/logger) so that a compromised controller cannot hide the truth.

---

4. Limitations

4.1 Real-data calibration and false positives

The most serious limitation is the real-data path. On 600 unmodified Hohenheim observations, the system produced 504 alert states (84.0%), with the first at step 93. The causes are structural:

- **Ambient vs cold-room sensors.** The primary `temperature` field is SENSOR01 (cold-room entry/ambient), which is around 21 °C early in the recording, while other sensors are in colder zones. A cold-storage envelope applied to an ambient sensor is not meaningful.
- **Hard-coded envelope.** The Hohenheim C3 path uses 4–16 °C and a special 25 °C allowance before step 120. The dataset's actual distribution is wider; the pre-`Begin` transient is not a production state.
- **Global spatial rule.** C4 uses `max(T) − min(T)` across all active sensors. In a multi-zone facility, a 21 °C ambient sensor and a 6 °C cold-room sensor legitimately differ by more than 5 °C; the rule then fires continuously.
- **Narrow ML baseline.** The environmental IsolationForest is fitted on the first 120 rows; later regimes (cooling ramp, door events) look anomalous.
- **Temporal coupling.** Once ML and C4 fire, the temporal engine escalates and the structural graph marks the environmental cluster, which drives the risk score above the 0.40 threshold.

The synthetic benchmark does not have this problem because it is calibrated to the simulated 4.2 °C cold room. The final report therefore treats the synthetic benchmark as the controlled evaluation and the real-data path as a deployment prototype that needs calibration. This is a defect to fix, not a result to hide.

4.2 Passive monitoring only

OPTIMUS observes data; it does not control the process. It cannot prevent a setpoint change, close a valve, switch to a backup controller, or fail safe. In the French incident, the physical impact was food spoilage and fire; analytics alone cannot prevent that. The system can shorten detection only if the controller reports the truth.

4.3 Replay and telemetry authenticity

Replay recall is 56.81% (static) and 66.37% (invariants), and replay evasion is 100% at full strength for every detector tested. The case study's `valid_frame_replay` and `hidden_hot_telemetry_replay` both return `NORMAL`. The current `step <= last_step` sequence check is insufficient: a replayed frame can carry a new step and a valid historical payload. Cryptographic freshness is required.

4.4 In-memory audit chain

The SHA-256 chain is in-memory. It detects tampering within the process, but it does not survive a restart, and an attacker with memory-write access can recompute it. Production needs append-only storage, external anchoring, and retention.

4.5 Synthetic benchmark vs real attacks

The quantitative benchmark is generated by the deterministic warehouse simulator, not by real attackers. It is useful for controlled comparison and ablation, but it cannot capture all real-world evasion. The case study is a scaled-down simulation on real telemetry, not a replay of the actual French campaign. The two evidence streams are complementary, and neither replaces a field pilot.

4.6 Mined invariants are statistical hypotheses

The miner discovered 9 candidates, activated 8, and rejected 1. The active invariants improved held-out recall, but they are learned from synthetic normal data and validated on synthetic attacks. They require domain review, independent data, operator approval, and rollback readiness. The 0.000417 FPR of the humidity-envelope candidate is small but non-zero; at scale it matters.

4.7 Adaptive fusion has limited effect

Adaptive fusion improved validation F1 (0.8581 → 0.8674) but did not change held-out rule classification and produced only a small risk-threshold difference. It is offline, trusted-label adaptation, not online learning from live traffic or attacker feedback. The static weights remain the explainable default.

4.8 No real ERP ledgers in the real dataset

The Hohenheim data has no inventory, capacity, or shipment ledgers. C1/C2 return `NOT_APPLICABLE` with zero penalty. The C1/C2 results in §2 come from the synthetic simulator. A real deployment must connect to the facility's ERP/WMS or accept that two of the four semantic invariants are dormant.

4.9 Case-study uncertainty

The exact initial access vector and whether CVE-2025-41450/51/52 were exploited in October 2026 are not confirmed by the authorities. The 50 °C, store counts, and fire reports come from press/retailer statements. The root-cause analysis separates confirmed facts from assessment, but a victim post-incident report would be stronger evidence.

4.10 Evaluation definition

The benchmark's detection criterion includes `POTENTIAL_ATTACK`, `COORDINATED_ATTACK`, or any security alert; the `joint_with_suspicious` ablation shows that including `SUSPICIOUS` raises recall to 83.73% at 0.29% FPR. The headline 76.93% is therefore conservative relative to a triage-inclusive operating point. The case study's `ExperimentEngine` outcome also treats risk ≥ 0.20 as detected, which is why some `SUSPICIOUS` results are labelled `TRUE_POSITIVE`. This is documented so the numbers are not over-read.

4.11 Model drift and maintenance

The ML detector is static after fitting. A real facility changes its product mix, door schedule, season, and setpoints; the baseline will drift. There is no automated retraining, drift alarm, or champion/challenger evaluation. The self-hardening loop adjusts a small set of semantic tolerances, not the ML model.

4.12 No cross-site correlation

The system monitors one facility. The French campaign hit hundreds of stores; a fleet-level view (same controller model, same firmware, same time window, same setpoint pattern) would have been a strong signal. OPTIMUS has no fleet analytics.

---

5. Future Work

5.1 Short term (next iteration)

1. **Fix the real-data calibration.** Zone-aware C4, per-sensor C3 envelopes, a representative ML baseline, and a drift monitor. Target: <1% alert rate on unmodified normal playback while preserving the large-excursion detection.
2. **Add controller/command telemetry.** Ingest login, setpoint, schedule, firmware, and configuration events; add a command-integrity layer; alert on out-of-window changes.
3. **Add replay protection.** Nonce, monotonic counter, timestamp window, edge HMAC/signature; reject unauthenticated telemetry or mark it untrusted.
4. **Persist the audit chain.** Append-only storage or SIEM forwarding; hash anchoring; retention.
5. **Add alert routing and a response playbook.** Webhook/email/SIEM, severity mapping, on-call runbook, maintenance-window allow-list.

5.2 Medium term

6. **Device identity and attestation.** Per-controller certificates/keys, firmware measurement, secure boot where available; treat the controller as an untrusted source until attested.
7. **OT network monitoring.** Integrate Zeek/OT IDS or flow telemetry; detect scanning, unexpected logins, and setpoint writes.
8. **Asset and exposure inventory.** Controller model, firmware, public exposure, vendor access; continuous scanning and patch SLA.
9. **Cross-site/fleet analytics.** Correlate the same controller/firmware/pattern across stores; campaign-level alerting.
10. **Safety interlock.** Independent over-temperature cutout and local alarm; fail-safe setpoints; test the failure mode.
11. **Expanded dataset.** Partner with a facility to obtain real ERP ledgers, controller logs, and incident labels; evaluate on real attacks.

5.3 Long term / research

12. **Online and drift-aware learning.** Semi-supervised updates, concept-drift detection, champion/challenger, human feedback with poison resistance.
13. **Causal/process-aware detection.** A refrigeration digital twin that predicts the expected temperature from door, compressor, and load events; residual-based detection with physical meaning.
14. **Federated cold-chain monitoring.** Learn across facilities without sharing raw operational data.

15. **Adversarial evaluation.** Red-team the monitor itself: in-envelope manipulation, replay, sensor suppression, label poisoning, and alert flooding.
16. **Regulatory and food-safety integration.** Map alerts to food-safety disposition, HACCP, and incident-reporting obligations.

---

6. Individual Contribution Statement

> Registration numbers are reproduced as supplied by the team. The team should verify the duplicate `24BBS0173` before submission.

Member	Registration no.	Primary contributions	Evidence
K. Pavan Kumar Reddy	24BBS0173	Threat modeling and security analysis; Review 3 incident case study (CERT-FR French refrigeration campaign); mapping to the Review 1 threat model; design of the scaled-down attack cases; interpretation of prevent/detect/miss results; report review and live-demo validation.	§3, `scripts/review3_case_study.py`, `evaluation_results/review3_case_study.*`
Durga Prassad	24BBS0195	Project lead; system architecture; `DefenderService` multi-layer pipeline; semantic invariants and joint decision fusion; SHA-256 audit chain; operator-gated self-hardening; evaluation harness (temporal splits, baselines, invariant mining, evasion frontier); Review 2/3 report integration; repository maintenance.	Git commits `44f6ce3`, `8a57aab`, `77468a1`, `8b57f16`; `app/defender/`, `app/evaluation/`
Sri Charan	24BBS0173	Data acquisition and Hohenheim dataset integration; SQLite synchronization and provenance; three-portal frontend (Defender, Transmitter, Simulator); experiment engine and simulator UI; dataset manifest/fetch script; tests and packaging.	Git commit `c729243`; `app/data_sources/`, `app/experiments/`, `app/frontend/`, `scripts/fetch_dataset.py`

Contribution matrix.

Area	Pavan	Durga	Sri Charan
Threat model and security analysis	●	○	○
Defender pipeline and decision fusion	○	●	○

Area	Pavan	Durga	Sri Charan
Audit chain and hardening	○	●	○
Data acquisition and provenance	○	○	●
Three-portal frontend	○	○	●
Experiment engine and attack scenarios	○	●	●
Evaluation and baselines	○	●	○
Case study and incident mapping	●	○	○
Report writing and review	●	●	○
Live demo and packaging	●	○	●

● = primary, ○ = supporting.

---

7. Review 3 Requirements Checklist

Review 3 requirement	Where addressed	Evidence
Final working system with a live demo	§1.1, §1.5	FastAPI app; endpoints verified; `/`, `/transmitter`, `/simulator` return 200; baseline/attack API results
Final source code repository	§1.6	GitHub repository; commit `8b57f16`; README
README covering setup, usage, reproduction	§1.6	`README.md`; commands; dataset fetch; test/benchmark commands
Final results and comparison	§2	Full benchmark, per-class, ablation, baselines, evasion, audit
Limitations and future work	§4, §5	Real-data FPR, replay, passive monitoring, audit persistence, case-study uncertainty; prioritized plan
Incident summary: what, timeline, impact	§3.2	CERT-FR alert; Reuters/Register reporting; impact table
Root cause: vulnerabilities, technical and process failures	§3.3	CVE table; technical/process failure lists; confirmed-

Review 3 requirement	Where addressed	Evidence
		vs-assessed table
Mapping to Review 1 threat model	§3.4	Threat-by-threat table; model updates
Prevent/detect/miss analysis	§3.5	Stage-by-stage table and narrative
Scaled-down simulated attack on the working system	§3.6	`scripts/review3_case_study.py`; 7 cases; JSON/Markdown artifacts
Gaps and recommendations	§3.7	Prioritized P0–P3 table; project-specific next steps
Authoritative public source, unique incident	§3.1	CERT-FR CERTFR-2026-ALE-012; Claroty; Danfoss; Reuters/Register
Design choices, security mechanisms, results, case study	§1.3, §1.4, §2, §3	Tables and measured results
Individual contribution statement	§6	Member table and matrix

7.1 Result-Integrity Statement

All benchmark, ablation, baseline, evasion, audit, latency, and case-study numbers in this report were produced by the team's own runs using the commands in §1.6 on 26 October 2026. The synthetic dataset is generated deterministically with seed 42; the case study uses the real Hohenheim telemetry and the live `DefenderService`/`ExperimentEngine`. No metric is copied from another project. The only numbers not measured by the team are the incident impact figures (store counts, 50 °C, fires), which are attributed to Reuters/The Register/retailer statements and are distinguished from CERT-FR-confirmed facts in §3.3.

---

8. References

1. CERT-FR (ANSSI), *Incident de sécurité ciblant les contrôleurs à distance des installations de réfrigération*, CERTFR-2026-ALE-012, 12–16 October 2026. https://cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-012/
2. Claroty Team82, *Freeze the Controller, Defrost the Food: Uncovering Vulnerabilities in Danfoss Refrigeration Controllers*. https://claroty.com/team82/research/freeze-the-controller-defrost-the-food-uncovering-vulnerabilities-in-danfoss-refrigeration-controllers
3. Danfoss, *Security advisory DSA-2025-08-01*.

https://www.danfoss.com/en/service-and-support/coordinated-vulnerability-disclosure/danfoss-security-advisories/dsa-2025-08-01/
4. Reuters, *French supermarket chain Intermarché hit by cyberattack, 150 stores targeted*, 12 October 2026. https://www.reuters.com/business/retail-consumer/french-supermarket-chain-intermarche-hit-by-cyberattack-150-stories-targeted-2026-10-12/
5. The Register, *Cyberattacks crank French supermarket refrigeration systems up to 50 °C*, 13 October 2026. https://www.theregister.com/2026/10/13/20267/
6. University of Hohenheim, *Temperature and Humidity Time Series of Cold Storage Room Monitoring*, Zenodo 15130001, DOI `10.5281/zenodo.15130001`, CC-BY-4.0. https://zenodo.org/records/15130001
7. NIST NVD, CVE-2025-41450, CVE-2025-41451, CVE-2025-41452. https://nvd.nist.gov/
8. OWASP Foundation, *OWASP Top 10* and *IoT Security Guidance*. https://owasp.org/
9. CISA, *Cyber Threats to Water and Wastewater Systems* / OT guidance (for the broader OT threat context). https://www.cisa.gov/
10. Project repository, `docs/REVIEW2_IMPLEMENTATION_AND_RESULTS.md`, `docs/SECURITY_MODEL.md`, `docs/ARCHITECTURE.md`, `docs/KNOWN_LIMITATIONS.md`, `docs/TESTING_AND_EVALUATION.md`. https://github.com/durga-61/optimus-purple-team

---

9. Appendix

A. Key API endpoints

Method	Path	Purpose
GET	`/api/health`	Health and active data source
GET	`/api/warehouse/current`	Current observation
POST	`/api/warehouse/seek`	Seek playback (operator)
POST	`/api/warehouse/step`	Advance one step (operator)
POST	`/api/warehouse/transmit`	Transmit a transmitter observation
POST	`/api/warehouse/mode/{mode}`	Switch `hohenheim`/`simulator`
GET	`/api/security/latest`	Latest analysis
GET	`/api/security/alerts`	Alerts
GET	`/api/security/events`	Audit events
GET	`/api/security/audit-chain/verify`	Verify SHA-256 chain

Method	Path	Purpose
GET	`/api/experiments/scenarios`	Scenario catalog
POST	`/api/experiments/baseline`	Run baseline
POST	`/api/experiments/attack`	Run controlled attack
GET	`/api/experiments/history`	Experiment history
GET	`/api/experiments/metrics`	Aggregate metrics
GET	`/api/experiments/history/export`	CSV export
GET	`/api/experiments/{id}/reproducibility`	Reproducibility record
GET	`/api/docs`	OpenAPI UI

B. Artifact index

Artifact	Purpose
`evaluation_results/final_benchmark/benchmark_summary.csv`	Overall test metrics
`evaluation_results/final_benchmark/per_class_metrics.csv`	Per-class metrics
`evaluation_results/final_benchmark/ablation_metrics.csv`	Layer ablation
`evaluation_results/final_benchmark/detailed_predictions.csv`	Per-observation predictions
`evaluation_results/final_benchmark/*.png`	Confusion matrix, per-class, latency, ablation charts
`evaluation_results/adaptive_fusion_comparison.json/.csv`	Static vs adaptive weights
`evaluation_results/invariant_mining_experiment.json`	Candidates, validation, activation
`evaluation_results/invariant_candidates.csv`	Candidate table
`evaluation_results/invariant_mining_comparison.csv`	Static vs invariants vs combined
`evaluation_results/baseline_comparison.json/.csv`	One-Class SVM and PCA

Artifact	Purpose
`evaluation_results/evasion_frontier.json/.csv/.png`	Evasion frontier
`evaluation_results/audit_lifecycle_verification.json`	Audit/lifecycle evidence
`evaluation_results/dataset_manifest.json`	Split sizes and SHA-256
`evaluation_results/artifacts_checksums.json`	SHA-256 for every artifact
`evaluation_results/review3_case_study.json`	Raw case-study results
`evaluation_results/review3_case_study.md`	Readable case-study tables
`scripts/review3_case_study.py`	Reproducible case-study runner
`docs/REVIEW3_FINAL_REPORT.md`	This report (Markdown)
`docs/REVIEW3_CASE_STUDY_RESULTS.md`	Readable case-study evidence (Markdown)
`docs/REVIEW3_FINAL_REPORT.pdf`	This report (PDF)

C. Glossary

- **C1:** capacity consistency (`inventory + free_capacity ≈ total_capacity`).
- **C2:** inventory-flow consistency (`I_t ≈ I_{t-1} + inbound − outbound`).
- **C3:** operating envelope (temperature/humidity bounds).
- **C4:** spatial consistency (`max(T) − min(T)` across active sensors).
- **FPR:** false-positive rate; **FNR:** false-negative rate; **TP/TN/FP/FN:** confusion counts.
- **EWMA:** exponentially weighted moving average.
- **OT:** operational technology; **ICS:** industrial control system; **SCADA:** supervisory control and data acquisition.
- **CERT-FR:** the French national computer emergency response team, operated by ANSSI.
- **Ground-truth isolation:** the Defender never receives attack labels.
- **Mined invariant:** a candidate rule learned from normal data, validated on independent data, and activated only after operator approval.

End of report.